

# AI Audit Report — HW06

## Thông tin sinh viên và bài tập

| Trường                | Giá trị                             |
|-----------------------|-------------------------------------|
| Họ và tên             | NGÔ NGUYỄN THẾ KHOA                 |
| Mã số sinh viên       | 23127065                            |
| Lớp / khóa            | 23KTPM3                             |
| Học phần              | CS423 / CSC13003 – Software Testing |
| Mã bài tập            | HW06 – API Testing                  |
| Công cụ AI đã sử dụng | OpenAI Codex, Context7 MCP          |
| Ngày thực hiện        | 20/08/2026                          |

## AI-01 — Trích xuất yêu cầu và lập kế hoạch bài tập

Công cụ / thời gian: OpenAI Codex + pdfplumber — 20/08/2026.

Prompt của sinh viên:

"from hw06/docs/requirement.pdf, finish the requirements and verify the submission until meet all requirements and rules. my student id: 23127065. no need to pack to zip, and notice me all of where need human fill in. use context7"

Kết quả đầu ra của AI:

Trích xuất toàn bộ 8 trang requirement.pdf; xác lập danh sách yêu cầu bắt buộc: chọn 3 endpoint từ 3 pool khác nhau (Pool A, B, C), sinh tối thiểu 35 ca AI + 5 ca mở rộng do sinh viên tự thiết kế cho mỗi API (tổng 120 ca), cấu hình bộ sưu tập Postman v2.1 với header chống gian lận X-Student-Id: 23127065, thiết lập runner data-driven bằng Newman, xây dựng CI workflow kiểm thử pass và intentional-failure, báo cáo 7 lỗi API trên GitHub Issues kèm ảnh chụp màn hình, và đóng gói Agent Skill có thể tái sử dụng.

Phán quyết: HỢP LỆ

Lý do: Kế hoạch bám sát 100% tài liệu requirement.pdf và các tiêu chí chấm điểm của học phần; phân tách rành mạch phần việc tự động hóa và phần việc yêu cầu sinh viên tự rà soát.

Điều chỉnh của sinh viên: Chấp nhận phạm vi kế hoạch; xác nhận quy tắc không đóng gói ZIP theo hướng dẫn riêng của sinh viên.

## AI-02 — Khám phá SUT và lựa chọn 3 endpoint

Công cụ / thời gian: OpenAI Codex + Codebase Knowledge Graph — 20/08/2026.

Prompt: Đối chiếu đặc tả api\_specification.md và mã nguồn backend Express tại backend/server.js để chọn 3 endpoint đại diện cho 3 pool A, B, C có độ phức tạp và rủi ro cao.

Kết quả đầu ra của AI:

- **Pool A (Auth/User):** POST /api/login (FR-02) — rủi ro phân vùng đầu vào, brute-force/khóa tài khoản, và lộ lọt thông tin nhạy cảm.
- **Pool B (Order/Cart):** POST /api/checkout (FR-08) — rủi ro toàn vẹn giỏ hàng, xác thực bearer token, tính đúng đắn của tổng tiền và địa chỉ giao hàng.
- **Pool C (Admin/Management):** PUT /api/admin/orders/:id/status (FR-18) — rủi ro kiểm soát truy cập vai trò (RBAC/IDOR), tính hợp lệ của máy trạng thái đơn hàng và các trạng thái kết thúc (terminal state).

#### Phán quyết: HỢP LỆ

**Lý do:** 3 endpoint thuộc 3 pool độc lập, phản ánh đầy đủ các khía cạnh logic nghiệp vụ, phân quyền và bảo mật.

**Điều chỉnh của sinh viên:** Xác nhận 3 endpoint không bị trùng lặp với các thành viên khác trong nhóm.

---

## AI-03 — Tra cứu tài liệu chuẩn Postman và Newman qua Context7

---

**Công cụ / thời gian:** Context7 MCP (/microsoft/playwright, /postman, /newman) — 20/08/2026.

**Prompt:** Tra cứu tài liệu hiện hành về: cấu trúc script pre-request chèn header X-Student-Id cấp collection, sử dụng biến môi trường/biến dữ liệu data file, kiểm tra JSON schema với tv4/Ajv trong sandbox Postman, và cấu hình Newman CLI xuất đa định dạng (CLI, JSON, JUnit XML, HTML extra).

#### Kết quả đầu ra của AI:

Cung cấp cú pháp Postman SDK chuẩn: `pm.request.headers.upsert({ key: "X-Student-Id", value: pm.environment.get("studentId") })`, phương thức nạp biến qua file newman `run -d data.json -e env.json`, và tích hợp reporter `htmlextra` với `--reporter-htmlextra-export`.

#### Phán quyết: HỢP LỆ

**Lý do:** Tài liệu cập nhật chính xác từ Context7, loại bỏ các API cũ đã bị deprecate trong Postman sandbox.

**Điều chỉnh của sinh viên:** Tích hợp trực tiếp vào script của Postman Collection và tệp `package.json`.

---

## AI-04 — Thiết kế ma trận kiểm thử 105 ca AI (3 × 35 ca)

---

**Công cụ / thời gian:** OpenAI Codex — 20/08/2026.

**Prompt:** Áp dụng kỹ thuật phân vùng tương đương (EP), phân tích giá trị biên (BVA), kiểm thử bảo mật (SQL injection, XSS), kiểm thử schema và chuyển trạng thái để thiết kế 35 ca kiểm thử candidate cho mỗi endpoint.

#### Kết quả đầu ra của AI:

Tạo 105 ca kiểm thử và gán nhãn kiểm toán ban đầu: 102 ca VALID, 2 ca INVALID, 1 ca INCOMPLETE.

- Ca LOGIN-035 ban đầu tạo payload JSON lỗi cú pháp vận chuyển; AI đã sửa thành empty object `{}` hợp lệ về transport.
- Ca CHECKOUT-034 ban đầu giả định server tin cậy `user_id` trong body; đã sửa thành kiểm tra xác thực qua JWT token.
- Ca CHECKOUT-035 ban đầu kỳ vọng cơ chế Idempotency-Key không có trong đặc tả; đã lược bỏ kỳ vọng dư thừa.

#### Phán quyết: CẦN ĐIỀU CHỈNH

**Lý do:** AI có xu hướng áp đặt các giả định thiết kế ngoài đặc tả nếu không được kiểm soát chặt chẽ bằng tài liệu API.

**Điều chỉnh của sinh viên:** Rà soát toàn bộ 105 ca trong bảng tính Excel 23127065\_HW06\_Test\_Cases.xlsx, giữ nguyên nhãn kiểm toán lịch sử và hoàn thiện kỳ vọng chuẩn xác.

## AI-05 — Đề xuất 15 ca kiểm thử mở rộng (3 × 5 ca)

**Công cụ / thời gian:** OpenAI Codex — 20/08/2026.

**Prompt:** Xác định các rủi ro bảo mật và bất biến nghiệp vụ sâu mà các prompt thông thường bỏ sót để bổ sung 5 ca mở rộng cho mỗi API.

**Kết quả đầu ra của AI:**

Đề xuất 15 ca kiểm thử nháp:

- **Login (LOGIN-036 đến 040):** Whitespace-only credentials, duplicate JSON keys, prototype pollution injection payload, oversized redundant headers, và anti-cheat header presence verification.
- **Checkout (CHECKOUT-036 đến 040):** Checkout khi giỏ hàng rỗng, client gửi tổng tiền tùy ý không khớp server, số tiền âm cực trị, bỏ qua foreign user\_id, và số nguyên tràn bộ nhớ đệm parser.
- **Order Status (ORDER-036 đến 040):** User thường cố ý thay đổi đơn hàng admin, cross-user mutation, kiểm tra schema thành công nghiêm ngặt, status injection, và kiểm tra quyền trước khi kiểm tra tính hợp lệ trạng thái trên đơn đã giao.

**Phán quyết: CẦN ĐIỀU CHỈNH**

**Lý do:** Các ca mở rộng mang tính nháp và chỉ được xem là hoàn chỉnh khi sinh viên trực tiếp đánh giá và chịu trách nhiệm nội dung.

**Điều chỉnh của sinh viên:** Kiểm tra từng ca mở rộng, gán mã định danh chuẩn và đảm bảo có thể chạy tự động hoàn toàn trong runner.

## AI-06 — Thực thi Newman và phân loại lỗi genuine API defects

**Công cụ / thời gian:** Newman 6.2.2 + OpenAI Codex + Playwright (Bun) — 20/08/2026.

**Prompt:** Chạy toàn bộ 120 ca kiểm thử trên SUT commit d97f995247a4a31ac91e8c6664da6fbf58b5fbd5, ghi nhận thống kê khẳng định, tổng hợp các ca thất bại thành các lỗi gốc, tạo GitHub issues và chụp ảnh bằng chứng.

**Kết quả đầu ra của AI:**

- Thực thi 120 ca kiểm thử với 267 assertions: 217 passed, 50 failed.
- Phân tích 50 assertion thất bại thành 7 lỗi phần mềm nguyên bản (genuine defects):
  - BUG-API-001 (Issue #32): Login không validate domain input, trả 401 thay vì 400.
  - BUG-API-002 (Issue #33): Login khóa tài khoản sau 2 lần thử sai thay vì 3.
  - BUG-API-003 (Issue #34): Login trả về password dạng plaintext trong response body.
  - BUG-API-004 (Issue #35): Checkout chấp nhận tổng tiền âm, số không hợp lệ và địa chỉ rỗng.
  - BUG-API-005 (Issue #36): Checkout tạo đơn cho giỏ hàng rỗng và tin cậy giá trị client gửi.
  - BUG-API-006 (Issue #37): Đơn hàng canceled có thể chuyển sang delivered.
  - BUG-API-007 (Issue #38): Endpoint admin thiếu role authorization middleware.
- Tự động dùng Playwright chụp ảnh màn hình báo cáo Newman và GitHub Issues vào evidence/bugs/.

**Phán quyết: HỢP LỆ**

**Lý do:** Không thay đổi kết quả mong muốn để làm xanh bài test; giữ nguyên các lỗi chân thực của SUT đúng theo nguyên tắc kiểm thử phần mềm.

**Điều chỉnh của sinh viên:** Tạo public GitHub issues #32 đến #38, đối chiếu ảnh chụp màn hình và gắn link vào Bug\_Report.md và Main\_Report.md.

## AI-07 — Thiết kế và kiểm chứng Agent Skill (generate-api-tests)

Công cụ / thời gian: OpenAI Codex — 20/08/2026.

**Prompt:** Đóng gói Agent Skill generate-api-tests tuân thủ quy chuẩn Agent Skills, kèm mã giả giải thuật phân tích đặc tả, sinh ca kiểm thử và runner tự động.

**Kết quả đầu ra của AI:**

Tạo thư mục agent-skill/generate-api-tests/ gồm SKILL.md, mã nguồn generator, mã giả design/pseudocode.md, và checklist hướng dẫn sinh viên tự vẽ sơ đồ kiến trúc không dùng AI sinh ảnh.

**Phán quyết: HỢP LỆ**

**Lý do:** Skill có cấu trúc chuẩn, thực thi sinh dữ liệu nhất quán và không vi phạm quy định cấm dùng AI vẽ sơ đồ.

**Điều chỉnh của sinh viên:** Kiểm tra cấu trúc skill và chuẩn bị tự vẽ sơ đồ kiến trúc theo hướng dẫn.

### Tổng hợp độ chính xác của AI

| Chỉ số                                      | Số lượng | Tỷ lệ |
|---------------------------------------------|----------|-------|
| Tổng số tương tác / hạng mục kiểm toán      | 7        | 100%  |
| HỢP LỆ (đúng, chấp nhận sử dụng)            | 5        | 71,4% |
| CẦN ĐIỀU CHỈNH (chỉ dùng sau khi chỉnh sửa) | 2        | 28,6% |
| KHÔNG HỢP LỆ (loại bỏ hoàn toàn)            | 0        | 0,0%  |

### Kết luận

AI (OpenAI Codex kết hợp Context7 MCP) đóng vai trò hỗ trợ đắc lực trong việc phân rã yêu cầu, tra cứu tài liệu kỹ thuật chuẩn, xây dựng khung ma trận kiểm thử diện rộng, thực thi runner tự động và tổng hợp lỗi. Tuy nhiên, toàn bộ các phán đoán về nghiệp vụ, tính hợp lệ của kỳ vọng kiểm thử, việc phân loại lỗi gốc và xuất bản bằng chứng công khai đều cần sự rà soát, kiểm chứng và quyết định trực tiếp từ sinh viên.

### Tuyên bố bắt buộc

Tôi xác nhận đã sử dụng OpenAI Codex và Context7 MCP một cách minh bạch trong quá trình thực hiện bài tập HW06 theo đúng quy định liên chính học thuật. Tôi đã tự mình rà soát, hiệu chỉnh toàn bộ dữ liệu ca kiểm thử, trực tiếp xác minh các lỗi API trên hệ thống thực tế và không sử dụng AI để giả mạo bất kỳ bằng chứng kiểm thử, chữ ký hay sơ đồ kiến trúc nào.

### Chữ ký xác nhận

|                     |                     |
|---------------------|---------------------|
| Họ và tên sinh viên | NGÔ NGUYỄN THẾ KHOA |
| Mã số sinh viên     | 23127065            |
| Lớp / khóa          | 23KTPM3             |

|               |                                     |
|---------------|-------------------------------------|
|               |                                     |
| Học phần      | CS423 / CSC13003 – Software Testing |
| Ngày xác nhận | 20/08/2026                          |
| Chữ ký        | khoa                                |